

Security+ 1.4 · Encrypting Data

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 1.4** —
Encrypting Data (9:48) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Data exists in three states: at rest (stored, e.g., BitLocker, TDE), in transit (moving over a network, e.g., TLS/VPN), and in use (being processed, e.g., confidential computing, CPU enclaves). Block ciphers (AES) encrypt data in fixed-size chunks (128-bit blocks), while stream ciphers (ChaCha20) encrypt byte-by-byte and are faster in software.

High-Yield Core Concepts Tested on Exam

- At rest = disk encryption; In transit = network encryption (TLS); In use = memory encryption (confidential computing)
- AES is a block cipher that encrypts in 128-bit blocks
- Stream ciphers like ChaCha20 are efficient on mobile devices without AES hardware acceleration
- Confidential computing protects data in use via CPU enclaves
- TDE (Transparent Data Encryption) protects data at rest in databases

Exam Tips & Classic Scenarios

- On the exam: 'data stored in the database' = at rest; 'during network transfer' = in transit
- Question about 'which provides protection for data in use' = confidential computing
- Block vs stream: AES = block; ChaCha20 = stream

Typical Exam Scenario: A company needs to protect data that is actively being processed in memory. This requires confidential computing or CPU enclaves (data in use protection).

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 1.4 — Encrypting Data)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Protecting data 'at rest' means encrypting:

- A)** Network traffic
- B)** Data written to storage/disk
- C)** The user's password
- D)** The source code

2. In at-rest encryption, where is data protected?

- A)** During transmission over the network
- B)** When stored on disk/databases
- C)** In memory during processing
- D)** In remote backups

3. TLS/SSL are protocols used to protect data:

- A) At-rest**
- B) In-transit**
- C) In use**
- D) In backup**

4. A characteristic of HASH (unlike encryption) is that it:

- A) Can be reversed with the key**
- B) Is one-way (not reversible)**
- C) Always shortens the text by half**
- D) Requires a key pair**

5. Corporate scenario (Encrypting Data): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'At rest = disk; In transit = network (TLS); In use = memory (most difficult).' What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Replace preventive technical controls with informal terms of adherence**
- C) Allow shared access among administrators using generic credentials**
- D) Implement the corresponding solution: At rest = disk; In transit = network (TLS); In use = memory (most difficult)...**

6. Corporate scenario (Encrypting Data): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'AES block cipher encrypts in 128-bit blocks'. What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Implement the corresponding solution: AES block cipher encrypts in 128-bit blocks...**
- C) Replace preventive technical controls with informal terms of adherence**
- D) Allow shared access among administrators with generic credentials**

7. Corporate scenario (Encrypting Data): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'Stream cipher: ChaCha20 — good for mobile, without AES hardware'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Stream cipher: ChaCha20 — good for mobile, without AES hardware...

8. Corporate scenario (Encrypting Data): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'On the exam: 'data stored in the database' = at rest; 'during network transfer' = in transit'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: On the exam: 'data stored in the database' = at rest; 'during network transfer...

9. Corporate scenario (Encrypting Data): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'Question: 'which provides protection for data in USE' = confidential computing'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Question: 'which provides protection for data in USE' = confidential computing.
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (Encrypting Data): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'Scenario: company needs to protect data that is BEING processed in memory' → confidential computing / enclaves (in use). What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Scenario: company needs to protect data that is BEING processed in memory...
- D)** Allow shared access among administrators using generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — Data written to storage/disk.

✓ **Why it's correct:** Protecting data 'at rest' means encrypting data stored on disk, storage, databases, backups, or any persistence medium. Encryption at rest ensures that even if the physical medium is stolen or improperly accessed, the data remains unreadable without the decryption key. In CompTIA Security+ SY0-701, this concept is covered as part of protecting data in different states: at rest, in transit, and in use. The correct answer refers specifically to data written to storage/disk, which is the exact definition of 'at rest'.

✗ **Why the others are wrong:**

- *Network traffic:* Encrypting network traffic refers to protecting data 'in transit', using protocols such as TLS, IPsec, or SSH. This protects communication between systems, but not stored data. The question asks about data 'at rest', which is a distinct state. Therefore, this alternative describes a different concept and does not answer the prompt.
- *The user's password:* Encrypting the user's password is a credential protection practice, typically done using hash functions (such as bcrypt, Argon2) and not reversible encryption. Additionally, a password is just a specific type of data, not encompassing the broad concept of data 'at rest'. Password protection is a subset of data security, but does not define what it means to protect data at rest.
- *The source code:* Source code is a type of data that can be at rest, in transit, or in use. Encrypting it would be a specific application of protection at rest, but it is not the general definition of the term. This alternative improperly restricts the concept to a single type of data, while the question seeks the broad and correct definition of 'data at rest', which encompasses any data stored on disk.

2) B — When stored on disk/databases.

✓ **Why it is correct:** At-rest encryption protects data when it is not in motion, i.e., when it resides on persistent storage media such as hard disk drives (HDDs), solid-state drives (SSDs), magnetic tapes, cloud storage volumes (e.g., Amazon EBS, S3), and database files. The goal is to ensure confidentiality and integrity if the physical medium is improperly accessed, stolen, or disposed of. At-rest encryption can be applied at full disk (FDE), volume, file, or database level, and is an essential control for compliance with regulations such as LGPD, GDPR, HIPAA, and PCI DSS. In the context of CompTIA Security+, at-rest encryption is classified as a data protection control for data at rest, distinct from in-transit encryption and in-use encryption.

✗ **Why the others are wrong:**

- *During transmission over the network:* This describes in-transit encryption, which protects data while it travels over networks using protocols like TLS, IPsec, SSH, and HTTPS. The focus is to prevent interception and tampering during communication. However, the question specifically refers to at-rest encryption, which deals with stored data, not data in motion. Therefore, this option is incorrect because it confuses the state of data: transmission versus rest.
- *In memory during processing:* This refers to in-use encryption, which protects data while it is being processed in RAM or in trusted execution environments (TEEs) like Intel SGX or AMD SEV. It is an emerging concept aimed at confidential computing scenarios. At-rest encryption does not apply to data in volatile memory, as it is not persistently stored. Thus, this option is wrong because it describes a different state (in use) and not the at-rest state.
- *In remote backups:* Remote backups are copies of data stored in different locations, typically for disaster recovery. Although they can be protected by at-rest encryption, the term 'remote backups' does not define the state of the data but rather the location and purpose of the copy. At-rest

encryption applies to any stored data, including backups, but this option is imprecise because it restricts the concept to a specific type of storage, excluding local disks, databases, and other repositories. Additionally, the question asks where data is protected, and 'remote backups' is a subset, not the general definition.

3) B — In-transit.

✓ **Why it is correct:** TLS (Transport Layer Security) and its predecessor SSL (Secure Sockets Layer) are cryptographic protocols that operate at the transport and application layers of the OSI/TCP-IP model. They are designed to protect data in-transit — that is, during transmission across the network. TLS/SSL provide confidentiality (symmetric encryption), integrity (HMAC), and authentication (digital certificates) for communications such as HTTPS, FTPS, and SMTPS. In CompTIA Security+, TLS/SSL are classic examples of controls that protect data in motion, mitigating attacks such as eavesdropping, man-in-the-middle, and tampering.

✗ **Why the others are wrong:**

- *At-rest:* At-rest encryption protects data stored on disk, in databases, or in backups. TLS/SSL do not act on data at rest, because they are communication protocols that only engage during transmission. This option is wrong because it confuses the data state: TLS/SSL do not encrypt files sitting idle, but rather the data flow between systems.
- *In use:* In-use encryption protects data while it is being processed in memory, using techniques such as secure enclaves (Intel SGX) or homomorphic encryption. TLS/SSL do not operate in this state, because they have no access to process memory, only to the communication channel. This option is incorrect because it describes a different data state than the one protected by TLS/SSL.
- *In backup:* Backups are copies of data stored for recovery. Although they can be protected by at-rest encryption, TLS/SSL are not used to encrypt backups themselves, but rather to protect the transmission of backup data across the network. This option is wrong because it restricts the scope to backups, whereas TLS/SSL protect any data in transit, regardless of whether it is a backup or not.

4) B — Is one-way (not reversible).

✓ **Why it is correct:** A fundamental characteristic of cryptographic hash functions is that they are one-way, i.e., not reversible. This means that from the hash, it is not possible to recover the original message. This property is known as pre-image resistance. Unlike encryption, which is reversible with the correct key, hashing is designed to be irreversible. CompTIA Security+ highlights that hash functions like SHA-256 are used for integrity and password storage (with salt), precisely because they cannot be reversed. The option 'Is one-way (not reversible)' correctly describes this essential characteristic.

✗ **Why the others are wrong:**

- *Can be reversed with the key:* This is a characteristic of symmetric or asymmetric encryption, not hash functions. In encryption, reversal is possible with the appropriate key (symmetric) or with the private key (asymmetric). Hash functions have no key and are not designed for reversal. Therefore, this statement is incorrect for hash. CompTIA Security+ emphasizes that hash is one-way and does not use keys, unlike cipher.
- *Always shortens the text by half:* Hash functions produce a fixed-size output regardless of input size. For example, SHA-256 always generates 256 bits (32 bytes). There is no 'shorten by half' rule; the digest size is constant and defined by the algorithm. Moreover, the hash function is not simple compression; it must be resistant to collisions and pre-image. This statement is technically false and does not describe a hash property.
- *Requires a key pair:* Hash functions do not use keys. They are public and deterministic algorithms that map input data to a digest. The use of a key pair is characteristic of asymmetric encryption.

(such as RSA or ECC), not hash. Although hashes can be used together with keys in HMAC, the hash function itself does not require keys. Therefore, this option is incorrect.

5) D — Implement the corresponding solution: At rest = disk; In transit = network (TLS); In use = memory (most difficult)....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Encrypting Data): Data at rest is encrypted on disk, data in transit is encrypted over the network using protocols like TLS, and data in use is encrypted in memory, which is the most challenging to protect due to active processing.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) B — Implement the corresponding solution: AES block cipher encrypts in 128-bit blocks....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Encrypting Data): AES block cipher encrypts in 128-bit blocks.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) D — Implement the corresponding solution: Stream cipher: ChaCha20 — good for mobile, without AES hardware....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Encrypting Data): Stream cipher: ChaCha20 — good for mobile, without AES hardware.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) D — Implement the corresponding solution: On the exam: 'data stored in the database' = at rest; 'during network transfer....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Encrypting Data): On the exam: 'data stored in the database' = at rest; 'during network transfer' = in transit. Data at rest refers to data stored on a device or database, while data in transit refers to data moving across a network. Encryption protects both states.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) C — Implement the corresponding solution: Question: 'which provides protection for data in USE' = confidential computing..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Encrypting Data): Question: 'which provides protection for data in USE' = confidential computing. Confidential computing protects data in use by performing computation in a hardware-based trusted execution environment; the appropriate control is to implement the corresponding solution, such as using secure enclaves.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

10) C — Implement the corresponding solution: Scenario: company needs to protect data that is BEING processed in memory....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Encrypting Data): Scenario: company needs to protect data that is BEING processed in memory → confidential computing / enclaves (in use). Confidential computing protects data in use by isolating it within hardware-based trusted execution environments (enclaves), ensuring that even the cloud provider or hypervisor cannot access the data while it is being processed.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks,

injections, or malware at runtime.

- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.